Student Exam Management System Threat Model

Owner: Emmanuel Adabra
Reviewer:
Contributors:
Date Generated: Sun Apr 26 2026

OWASP Threat Dragon

Executive Summary

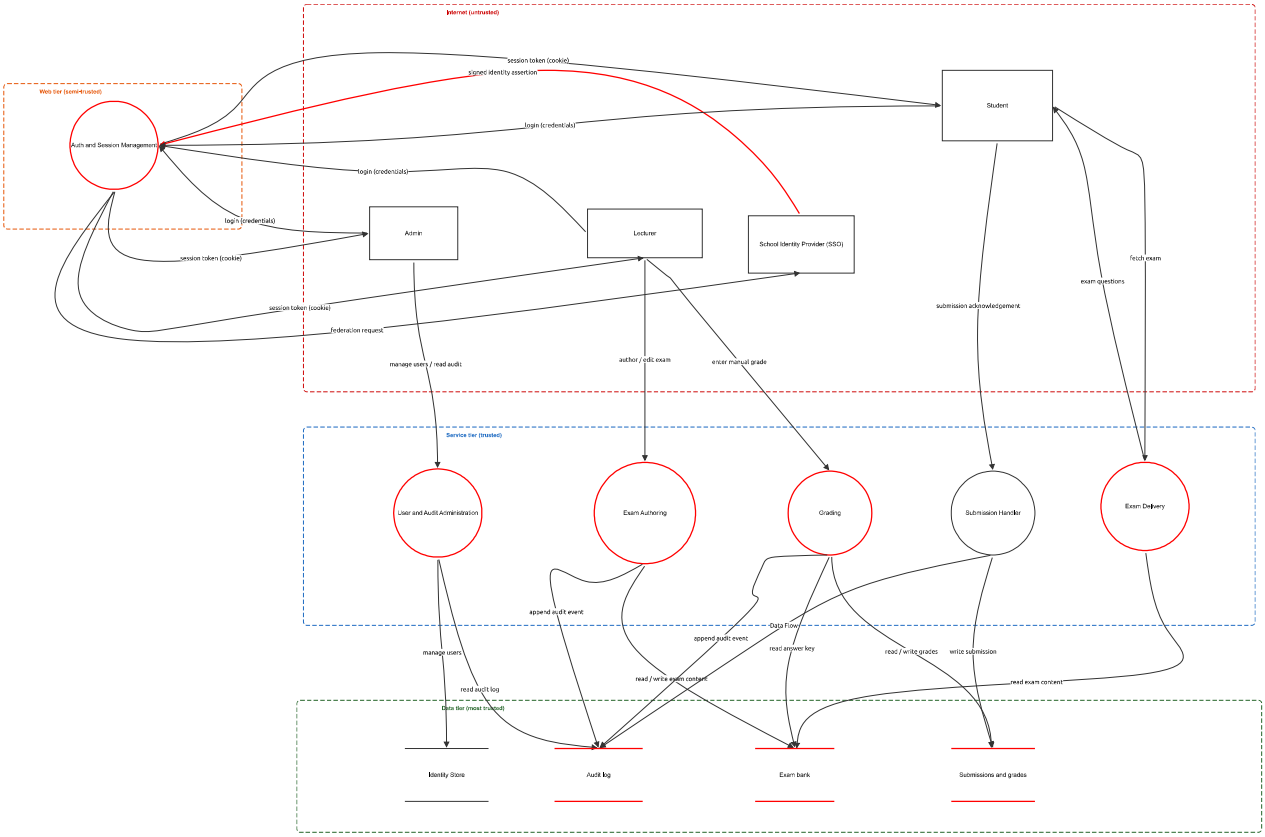
High level system description

Threat model for a hypothetical web-based exam platform supporting student exam taking, lecturer exam authoring and grading, and administrator user and audit management. Federated authentication via a school identity provider

Summary

Total Threats	9
Total Mitigated	0
Total Open	9
Open / Critical Severity	4
Open / High Severity	4
Open / Medium Severity	1
Open / Low Severity	0

Level 1 - SEMS DFD



Level 1 - SEMS DFD

User and Audit Administration (Process)

Description: Exposes privileged admin operations: create or disable accounts, assign roles, and read audit log entries. All actions are written to DS4. Elevation-of-privilege risk if authorisation checks are absent.

Properties: Web Application, Privilege Level: High

Number	Title	Type	Severity	Status	Score	Description	Mitigations
9	IDOR on role-assignment endpoint allows self-promotion	Elevation of privilege	Critical	Open	8.6	The admin role-assignment endpoint takes a user ID and a target role from the request body. If the server-side authorisation check is missing or only validates session presence rather than role, a logged-in student can issue a request that promotes their own account to lecturer or admin.	Server-side authorisation check that resolves the caller's role on every request and rejects role-changing actions for non-admins; deny by default; canonical authorisation helper used by every privileged endpoint; access-control test suite executed in CI on every change to authorisation code

Exam Authoring (Process)

Description: Allows lecturers to create, edit, and publish exams and answer keys in DS2. Pre-publish edits are unrestricted; post-publish edits require dual-control approval and produce an audit event.

Properties: Web Application, Privilege Level: High

Number	Title	Type	Severity	Status	Score	Description	Mitigations
6	Pre-exam answer key exposure via insecure direct object reference	Information disclosure	High	Open	7.2	A student who discovers the exam ID can request the exam-authoring API endpoint and retrieve the answer key before the exam window opens. The endpoint does not enforce role separation between the authoring-write and grading-read paths.	Enforce role-based access control on all exam-authoring endpoints; answer keys must only be readable by the grading service account and the owning lecturer; all answer-key reads produce audit events; keys are stored encrypted at rest and decrypted only inside the grading service.

Grading (Process)

Description: Applies the answer key to MCQ and short-answer submissions, accepts lecturer-entered marks for open-ended answers, computes the final grade, and publishes it to the student via DS3.

Properties: Privilege Level: Medium

Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	Grade tampering via direct DS3 write from compromised grading service	Tampering	High	Open	7.6	An attacker who compromises the grading service account can issue arbitrary UPDATE statements against DS3, altering grades without going through the normal grading workflow. There is no secondary approval mechanism for grade changes.	Separate DB accounts per service; grading service account has no direct UPDATE on final-grade columns; grade changes must go through an audited stored procedure; all writes produce audit events.

Exam Delivery (Process)

Description: Loads an active exam for a logged-in student, serves questions, and enforces the per-student countdown timer. Read-only against DS2; writes nothing to the exam bank.

Properties: Web Application, Privilege Level: Low

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	Concurrent exam-start storm exhausts the application thread pool	Denial of service	Critical	Open	8.4	Several thousand students start the same exam at the same scheduled minute. Each session triggers a synchronous read of the entire exam from DS2, exhausting the application thread pool and the database connection pool. Legitimate students cannot start the exam.	Pre-fetch exam content into per-session cache at seat allocation; auto-scale on connection-pool saturation; connect-time admission control (queue with progress feedback) when capacity is exceeded; capacity tested against the largest scheduled cohort plus 50% headroom.

Auth and Session Management (Process)

Description: Validates credentials, brokers OIDC/SAML federation with the school identity provider, issues and refreshes session tokens, enforces MFA, and writes authentication events to the audit log.

Properties: Web Application, Privilege Level: Medium

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	Credential stuffing during open exam window	Spoofing	Critical	Open	8.2	Attackers replay leaked passwords from public breach corpora against the login endpoint during a scheduled exam window. A successful match grants a session that is indistinguishable from a legitimate student's. The attack is high-volume and timed to maximise impact.	Mandatory MFA for all roles; per-account and per-IP rate limiting on /login; CAPTCHA after N failed attempts; anomaly-detection alert on geographic or device deltas during exam windows; integration with breached-password APIs (HIBP) at password-set time.

signed identity assertion (Data Flow)

Description: SAML assertion or OIDC id_token returned by the IdP, cryptographically signed with the IdP private key.

Properties: Encrypted, Protocol (HTTPS)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
2	Tampering with the SSO identity assertion	Tampering	High	Open	7.4	A man-in-the-middle on a compromised network modifies the SAML or OIDC assertion in transit, swapping the asserted identity before P1 consumes it. If P1 does not validate the issuer signature, audience, and nonce, the attacker logs in as any user.	HTTPS with HSTS preload; full validation of issuer signature, audience, nbf/exp, and per-request nonce; reject assertions over plain HTTP; pin the IdP signing key.

Audit log (Store)

Description: Append-only log of authentication, authoring, submission, grading, and admin events. Each entry is hash-linked to the previous for tamper-evidence. Write-once; the application service account has INSERT only — no UPDATE or DELETE.

Properties: Is a Log, Encrypted, Signed

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	Insider with database admin rights deletes audit entries	Tampering	Medium	Open	6.0	A database administrator, or an attacker who has compromised the DBA account, deletes or rewrites entries in DS4 to cover unauthorised actions. Because the audit log lives in the same database as the data it audits, a single privileged actor can both act and erase the trace.	Ship audit events to a separate trust zone (write-once medium or external SIEM) on creation; append-only schema enforced by database privileges (REVOKE DELETE, REVOKE UPDATE); periodic hash anchoring of the audit chain to an immutable store; separation of duties between database administrator and application owner roles.

Exam bank (Store)

Description: Exam metadata, questions, and answer keys. Answer keys are stored encrypted and are only decrypted inside the grading service. Pre-exam confidentiality is critical; unauthorised read before the window opens constitutes cheating.

Properties: Encrypted

Number	Title	Type	Severity	Status	Score	Description	Mitigations
11	Pre-exam answer key exposure via direct URL access	Information disclosure	High	Open	7.4	Provide a desA student who discovers or guesses the exam resource URL (e.g. `/api/exams/{id}/answers`) can request the answer key directly before the exam window opens. The exam-authoring endpoint that lecturers use to read the key shares the same route or an adjacent one, and if the server-side role check is absent or checks only authentication (session present) rather than authorisation (role = lecturer or grader), any authenticated student can retrieve the full answer key in plaintext before sitting the exam. The exam ID is often sequential or derivable from the student's own exam-start response, making discovery low-effort.cription for this threat	Provide remediaEnforce role-based access control on all DS2 read paths — the answer key columns must only be readable by the grading service account (P4.1) and the owning lecturer (P5), never by the student role; separate the student-facing exam-content endpoint from the answer-key endpoint at the routing layer; answer keys are stored encrypted with a key that is only released to P4.1 after the exam window closes; all answer-key reads produce an audit event in DS4 (Level 1) / DS3c (Level 2); alert on any answer-key read that occurs before the window-open timestamption for this threat or a reason if status is N/A

Submissions and grades (Store)

Description: Per-student answers, content hashes, marks, and final grades. Contains student PII. Column-level encryption on PII fields; access is role-separated between the submission, grading, and publishing service accounts.

Properties: Encrypted

Number	Title	Type	Severity	Status	Score	Description	Mitigations
4	Mass disclosure of grades and student PII via lateral movement	Information disclosure	Critical	Open	8.0	An attacker who has compromised a low-privilege application account pivots laterally to the database account used by the grading service and exfiltrates the entire student PII and grade record set in one query.	Column-level encryption for student PII; database role separation (grading service has read on grades only, not on PII); parameterised queries throughout; principle of least privilege on the database account; egress alerting on bulk reads from sensitive tables.